

Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☒	☐	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.

- | | | |
|--------------------------|-------------------------------------|---|
| ☐ | ☒ | Enforce privacy policies, procedures, and processes to properly document and maintain data. |
|--------------------------|-------------------------------------|---|

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☒	☐	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

- **Least Privilege & Separation of Duties:** Implement strict least privilege access controls and separation of duties to restrict unauthorized access to cardholder data and sensitive internal systems.
 - **Risk Score:** Critical
 - **Control Owner:** IT Access Management Team
- **Disaster Recovery & Business Continuity Plans:** Establish and regularly test comprehensive disaster recovery and business continuity plans to ensure rapid restoration of critical systems following a disruptive event.

- **Risk Score:** High
 - **Control Owner:** Incident Management & Operations Team
- **Network Firewalls:** Deploy next-generation firewalls at all network perimeters to inspect traffic, filter out malicious payloads, and segment internal environments.
 - **Risk Score:** High
 - **Control Owner:** IT Network Security Team
- **Intrusion Detection & Prevention Systems (IDS/IPS):** Implement IDS/IPS solutions to monitor network traffic for anomalous behavior, known attack signatures, and unauthorized access attempts in real time.
 - **Risk Score:** High
 - **Control Owner:** Security Operations Center (SOC) / IT Network Team
- **Automated Database & System Backups:** Enforce automated, immutable, and encrypted backup routines for all core databases and systems, verifying recovery point and time objectives (RPO/RTO) regularly.
 - **Risk Score:** High
 - **Control Owner:** IT Infrastructure & Reliability Team
- **Data Encryption (In Transit & At Rest):** Mandate robust encryption standards (e.g., AES-256 for data at rest, TLS 1.3 for data in transit) across all payment touchpoints and PII repositories to satisfy PCI DSS and GDPR mandates.
 - **Risk Score:** Critical
 - **Control Owner:** Security Engineering Team
- **Enterprise Password Management & Policies:** Deploy a centralized enterprise password manager, enforce multi-factor authentication (MFA), and prohibit weak or default credentials across all employee accounts.
 - **Risk Score:** Medium
 - **Control Owner:** IT Access Management & Identity Team
- **Legacy System Monitoring & Maintenance:** Establish dedicated manual monitoring, hardening, and isolated maintenance protocols for unpatchable or legacy retail systems.
 - **Risk Score:** Medium
 - **Control Owner:** IT Operations & Infrastructure Team
- **Data Classification, Inventory, & Privacy Governance:** Implement formal data asset tagging, thorough inventories, and privacy workflows to ensure compliance with GDPR consumer rights and SOC trust service criteria.

- **Risk Score:** High
- **Control Owner:** Compliance & Privacy Team